

Relatório de Auditoria de Vulnerabilidades — Metasploitable 2

Disciplina: Segurança Digital · **Aluno:** José Otávio Ribeiro Baggio

Alvo: Metasploitable 2 (Linux kernel 2.6.24-16-server)

A auditoria encontrou três falhas na máquina virtual analisada: o sistema entrega informações internas a qualquer usuário, o arquivo de senhas pôde ser lido e tinha senhas fracas, e o kernel tem uma falha (Dirty COW) que deixa um usuário comum virar administrador. As duas últimas são críticas.

Falha 1 — O sistema entrega informações internas a qualquer usuário

Gravidade: média. O Linux guarda em pastas especiais (`/sys` e `/proc`) dados sobre o hardware e o kernel. Normalmente isso ajuda o sistema a funcionar, mas alguns desses arquivos estavam liberados para leitura por qualquer pessoa, mesmo sem ser administrador.

Lendo o arquivo `/sys/kernel/notes`, apareceu esta assinatura:

```
XenlinuxXen2.Xenxen-3.0XenXenCXenI*  
Xen!writable_page_tables|pae_pgdir_above_4gb XenYXengenericGNUvJvH,  
Isso revela duas coisas que o sistema não deveria contar: que ele não é um computador físico, e sim uma máquina virtual rodando sobre o virtualizador Xen; e que usa um kernel 2.6.24 de 32 bits com suporte a PAE.
```

Por que isso importa. Saber exatamente onde o sistema roda e qual kernel ele usa poupa trabalho do atacante: em vez de testar no escuro, ele vai direto atrás de falhas conhecidas daquela versão do Xen e daquele kernel. É informação que, sozinha, não invade nada — mas facilita todo o resto do ataque.

Como corrigir:

1. Restringir a leitura das pastas sensíveis de `/sys` e `/proc` para que só o administrador (root) consiga inspecioná-las.
2. Ativar o `kptr_restrict` com valor 2 (em `/proc/sys/kernel/kptr_restrict`), para o kernel esconder endereços de memória e assinaturas internas.

Falha 2 — Arquivo de senhas liberado e senhas fracas

Gravidade: crítica. No Linux, as senhas ficam guardadas (de forma embaralhada) no arquivo `/etc/shadow`, que deveria ser legível **somente pelo administrador**. Na máquina auditada, um usuário comum conseguiu ler esse arquivo inteiro com `cat /etc/shadow`. Pior: as senhas usavam um embaralhamento antigo e fraco (MD5), e várias eram óbvias.

Conteúdo completo coletado do `/etc/shadow`:

```
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::  
daemon*:14684:0:99999:7:::  
bin*:14684:0:99999:7:::  
sys:$1$fUX6BP0t$MiyC3Up0zQJqz4s5wFD9l0:14742:0:99999:7:::  
sync*:14684:0:99999:7:::  
games*:14684:0:99999:7:::
```

```

man*:14684:0:99999:7::
lp*:14684:0:99999:7::
mail*:14684:0:99999:7::
news*:14684:0:99999:7::
uucp*:14684:0:99999:7::
proxy*:14684:0:99999:7::
www-data*:14684:0:99999:7::
backup*:14684:0:99999:7::
list*:14684:0:99999:7::
irc*:14684:0:99999:7::
gnats*:14684:0:99999:7::
nobody*:14684:0:99999:7::
libuuid!:14684:0:99999:7::
dhcp*:14684:0:99999:7::
syslog*:14684:0:99999:7::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7::
sshd*:14684:0:99999:7::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7::
bind*:14685:0:99999:7::
postfix*:14685:0:99999:7::
ftp*:14685:0:99999:7::
postgres:$1$Rw35ik.x$MgQgZUu05pAoUvfJhfcYe/:14685:0:99999:7::
mysql!:14685:0:99999:7::
tomcat55*:14691:0:99999:7::
distccd*:14698:0:99999:7::
user:$1$HESu9xrH$k.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7::
service:$1$kR3ue7JZ$7GxELDupr50hp6cjZ3Bu//:14715:0:99999:7::
telnetd*:14715:0:99999:7::
proftpd!:14727:0:99999:7::
statd*:15474:0:99999:7::

```

Como ler esse arquivo

Cada linha é uma conta, no formato `usuário:senha:...`. O que está no campo da senha diz tudo:

- `*` — conta travada, sem senha para login. São contas de serviços internos (impressão, e-mail, SSH, etc.), não dá para entrar com elas por senha.
- `!` — conta também bloqueada (ex.: `libuuid`, `mysql`, `proftpd`).
- `$1$...` — aqui mora o perigo: existe uma senha real embaralhada com MD5. O `$1$` identifica o MD5; logo depois vem um "tempero" (*salt*) aleatório e, por fim, o embaralhado. Como o MD5 é rápido de calcular, um computador comum testa milhões de senhas por segundo até acertar.

Senhas que foram recuperadas

Como o ataque é feito **offline** (no arquivo copiado, sem tocar no sistema alvo), não há risco de travar contas nem de disparar alarmes. Testando com um dicionário de senhas comuns, todas as contas com `$1$` caíram:

Conta	Senha recuperada	Para que serve
root	root	Administrador supremo do sistema

Conta	Senha recuperada	Para que serve
msfadmin	msfadmin	Conta principal de uso da máquina (tem poderes de admin)
user	user	Usuário comum de teste
service	service	Conta de serviço genérica
postgres	postgres	Administrador do banco de dados PostgreSQL
sys	batman	Conta de sistema antiga do Unix
klog	123456789	Conta ligada ao registro de logs do kernel

Explicando algumas delas

- **root** — é a conta mais importante: quem a controla controla a máquina inteira. Ter a senha `root` significa comprometimento total. Bastou digitar `su root` e informar `root` para assumir o terminal de administrador.
- **msfadmin** — é a conta "do dia a dia" do Metasploitable e também tem privilégios administrativos (via `sudo`). Com senha igual ao nome (`msfadmin`), é um alvo imediato.
- **postgres** — é o dono do banco de dados. Com a senha `postgres`, um atacante lê, altera ou apaga todos os dados guardados no banco.
- **sys** e **klog** — são contas de sistema. Chamam atenção porque não deveriam ter senha de login simples: `batman` e `123456789` são justamente o tipo de senha que qualquer lista de ataque testa primeiro.
- **contas com * (daemon, bin, mail, sshd, ...)** — não foram quebradas porque nem têm senha: são processos internos do sistema. Aparecem no arquivo, mas não servem de porta de entrada por senha.

Como corrigir:

1. Corrigir as permissões do arquivo: `chmod 600 /etc/shadow` e `chown root:root /etc/shadow`, para que só o root consiga lê-lo.
2. Trocar o embaralhamento antigo (MD5, \$1\$) por um moderno, como SHA-512 (\$6\$) ou Argon2id, na configuração do PAM.
3. Exigir senhas fortes: no mínimo 12 caracteres, com maiúsculas, minúsculas, números e símbolos — e trocar imediatamente todas as senhas padrão.

Falha 3 — Dirty COW: virar administrador por uma falha do kernel

Gravidade: crítica. O kernel 2.6.24 dessa máquina tem uma falha famosa chamada **Dirty COW**. Ela deixa um usuário comum reescrever arquivos que, em tese, só o administrador poderia alterar — e, com isso, se tornar root.

A ideia, sem jargão. Para economizar memória, quando várias pessoas abrem o mesmo arquivo, o Linux mostra a todos a mesma cópia "só leitura". Se alguém tenta alterar, o sistema cria rapidinho uma cópia privada e deixa a pessoa mexer só nela, preservando o arquivo original. Essa técnica se chama *Copy-on-Write* (copiar ao escrever).

O truque do ataque. A falha está no tempo. O exploit faz duas coisas ao mesmo tempo, num loop muito rápido: numa ponta, tenta escrever na cópia privada; na outra, manda o sistema descartar essa cópia privada. Se o tempo coincidir por uma fração de segundo, a escrita acontece bem na hora em que a cópia sumiu — e o sistema acaba gravando a alteração no **arquivo original protegido**, não na cópia. É a tal "condição de corrida": duas operações disputando o mesmo instante.

O que isso permite. Com esse exploit, um usuário sem privilégios consegue, por exemplo, adicionar a si mesmo como administrador no `/etc/passwd`, ou injetar código em programas legítimos do sistema. Na prática, ignora todas as permissões de arquivo e vira root na hora.

Como corrigir: atualizar o kernel para uma versão corrigida é a única solução real — a falha está no próprio kernel, não em uma configuração. Como o Metasploitable 2 é propositalmente antigo, aqui ela serve de exemplo de por que manter o sistema atualizado é indispensável.

Matriz de risco

Vulnerabilidade	Como é explorada	Gravidade	Correção
Vazamento de dados do sistema/virtualizador	Leitura de arquivos de <code>/sys</code> por usuário comum	Média	Restringir permissões e ativar <code>kptr_restrict</code>
Leitura indevida do arquivo de senhas	Acesso direto via <code>cat /etc/shadow</code>	Crítica	<code>chmod 600 /etc/shadow</code> e <code>chown root:root</code>
Senhas fracas e embaralhamento obsoleto	Força bruta offline / adivinhação	Crítica	Trocar senhas padrão e migrar MD5 para SHA-512
Dirty COW (falha no kernel)	Condição de corrida escrevendo em arquivo protegido	Crítica	Atualizar o kernel para versão corrigida